



2016 中国互联网安全大会
China Internet Security Conference

协同联动 共建安全+命运共同体

“白帽子”安全漏洞挖掘 法律风险分析报告

黄道丽

公安部第三研究所网络安全法律研究中心主任/ 副研究员
西安交通大学信息安全法律研究中心 博士

漏洞治理成为网络安全保障的基础性环节

- ◆ 习总书记4.19讲话，**全天候全方位感知网络安全态势**：建立统一高效的**网络安全风险报告**机制、**情报共享**机制、**研判处置**机制，**准确把握**网络安全**风险**发生的规律、动向、趋势；建立政府和企业网络安全**信息共享**机制；
- ◆ 《国家信息化发展战略纲要》：提升全天候全方位感知网络安全态势能力，做好等级保护、风险评估、**漏洞发现**等基础性工作。

漏洞治理成为网络安全保障的基础性环节

- ◆ 我国亟需从管理、技术和法律层面综合提高**应对网络攻击**的防御**能力**，最大限度**减少**安全漏洞可能产生的**危害**，同时**引导**安全漏洞的合法挖掘、报告、披露和利用，为发展国家安全反制能力打下基础，从**整体**上**提升**国家的网络安全保障能力。



中国互联网安全大会



360互联网安全中心

目 录

- ◆ 安全事件回顾与基本概念解析
- ◆ 我国漏洞挖掘的法律遵从框架及风险分析
- ◆ 国外安全漏洞挖掘的最佳实践及立法
- ◆ “白帽子”漏洞挖掘的积极效应和法律建议
- ◆ 构建国家层面网络安全命运共同体的对策建议

报告图表



中国互联网安全大会



360互联网安全中心

表 1国内外漏洞概念梳理

表 2我国“白帽子”漏洞挖掘法律遵从框架

表 3企业/众测平台的漏洞奖励金额

表 4国外漏洞挖掘的法律框架

表 5“白帽子”漏洞挖掘的法规遵从对比表

图 1漏洞的三个主要特征

图 2缩减版的安全业态

图 3“白帽子”漏洞挖掘的法律风险来源

附件1国内外众测平台梳理表

附件2国内外国家漏洞平台梳理表

附件3专业术语中英文对照表

基本概念解析

安全漏洞的概念混用

- ◆ 漏洞（Vulnerability）又称脆弱性，是硬件、软件、协议或使用策略上无意产生的缺陷，具备能被利用而导致安全损害的特性
- ◆ 漏洞和安全漏洞混同使用
- ◆ 概念解析：安全漏洞、白帽子、众测平台、国家漏洞平台、漏洞挖掘、漏洞奖励、关键基础设施、瓦森纳协定

“白帽子” 漏洞挖掘的法律遵从框架

安全漏洞的概念混用

- ◆ 有关我国“白帽子”漏洞挖掘的法律遵从条款，零散的体现在《保守国家秘密法》《治安管理处罚法》《刑法》《国家安全法》《网络安全法（草案二次审议稿）》等法律中，尚未形成系统的法律体系。

“白帽子” 漏洞挖掘的法律遵从框架



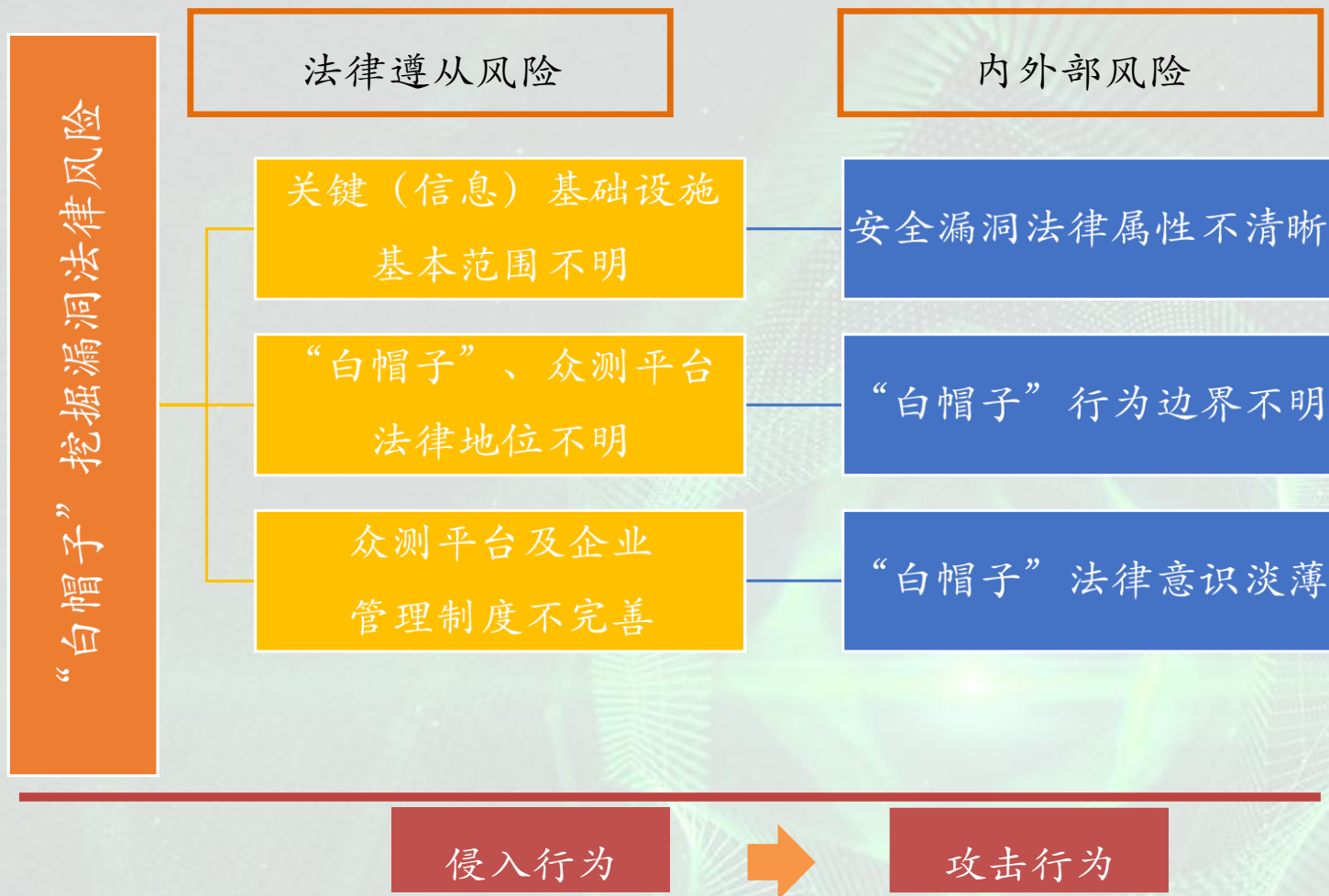
- ◆ 我国法律目前缺少对安全漏洞的挖掘、报告、披露、交易和利用等方面的直接规定，针对非授权访问行为规定了惩戒性条款，不涉及安全漏洞、“白帽子”、众测平台等概念，亦缺少漏洞挖掘行为的正面规范指引。
- ◆ 从现有《刑法》《治安管理处罚法》等法律条款剖析，“白帽子”的漏洞挖掘行为很容易碰触法律边界，对企业发展 and 安全防护产生负面效应。

“白帽子” 漏洞挖掘的法律遵从框架



- ◆ 作为我国**网络安全保障基本法**的《网络安全法（草案二次审议稿）》发布，涉及漏洞的规定变更为6条，考虑到“**一些地方、部门和企业提出，当前一些个人和机构随意发布系统漏洞等网络安全信息，对维护网络安全影响较大，应予规范。**”
- ◆ “开展网络安全认证、检测、风险评估等活动，向社会发布系统漏洞、计算机病毒、网络攻击、网络侵入等网络安全信息，应当遵守国家有关规定。”

“白帽子”漏洞挖掘的法律风险来源



- ◆ 漏洞研究最佳实践：漏洞奖励/悬赏计划、企业金钱奖励计划、政府金钱奖励计划。
- ◆ 企业和“白帽子”之间所持的**不同利益**，以及漏洞自身具有的**攻击和资源兼备性**日益复杂，都呼唤中立的第三方协调漏洞挖掘和报告行为，以确保**能力差异和利益冲突**不会**妨害提升网络安全**这一总目标的实现。
- ◆ 第三方众测平台盛行，以商业经营模式扮演着协调漏洞发现和披露的角色，**美国HACKERONE众测公司**。

国外安全漏洞挖掘的最佳实践



中国互联网安全大会



360互联网安全中心

- ◆ 惠普诉SNOSOFT 公司研究者案件
- ◆ “黑掉五角大楼” 项目启动
- ◆ 苹果赞越狱社区对IOS安全
- ◆ 苹果不打算起诉FBI

国外安全漏洞挖掘的立法

- ◆ 1998 《数字千年版权法》（第1201条）
- ◆ 2001年美国《爱国者法案》
- ◆ 2002年美国《关键基础设施信息保护法》
- ◆ 2012年美国《网络安全法案》
- ◆ 2015年美国关于修改《计算机欺诈和滥用法》的提案
- ◆ 2015年美国《网络安全信息共享法案》
- ◆ 2015年美国《国家网络安全保护增强法》
- ◆ 2001欧盟《网络犯罪公约》
- ◆ 2011年欧盟《隐私及电子通讯指令》
- ◆ 《2013/40/EU号针对网络攻击的指令》

国外安全漏洞挖掘的立法特点和趋势



中国互联网安全大会



360互联网安全中心

- ◆ 关键信息基础设施漏洞挖掘的绝对禁止
- ◆ 对漏洞挖掘的授权作扩大解释
- ◆ 特殊目的下漏洞挖掘的豁免
- ◆ 注重对“白帽子”身份的认可和招募

我国“白帽子”漏洞挖掘的法律建议



中国互联网安全大会



360互联网安全中心

建议一 关键信息基础设施的内涵和外延界定

我国“白帽子”漏洞挖掘的法律建议



中国互联网安全大会



360互联网安全中心

建议二 相关主体概念和法律地位确定

- 1) 众测平台属于网络信息安全测试、评估行业的服务（电商）平台
- 2) “白帽子”属于网络安全服务行业不特定服务的独立提供者
- 3) 企业属于接受安全服务，并适度减轻缺陷责任的受测对象

我国“白帽子”漏洞挖掘的法律建议



建议三 “白帽子” 的权利和义务规范

- 1) 以“白帽子”注册为一般、匿名为例外的备案制度是行为规范的基本前提
- 2) 以众测平台的运营模式为基础，规范“白帽子”行为
- 3) 通过行业规范强化“白帽子”的道德感和职业操守，明确其行为的法律边界
- 4) “白帽子”定期法律知识培训

建议四 众测平台的协调监督义务

- 1) 基于身份核验的资质审查义务，以避免“白帽子”损害企业利益
- 2) 基于合理审慎义务，以避免企业损害“白帽子”的合法权益

“白帽子” 漏洞挖掘的法律建议



中国互联网安全大会



360互联网安全中心

建议五 漏洞挖掘的豁免条件

- 1) 区分受测对象的豁免与否
- 2) 区分挖掘类型的豁免与否

“白帽子”漏洞挖掘的法规遵从对比



中国互联网安全大会



360互联网安全中心

综上，按照本报告设想的法律建议进行完善后的法律框架将更注重国际现行发展趋势，对出于安全研究、国家安全等特殊目的的漏洞挖掘给予适当豁免（见表5：“白帽子”漏洞挖掘的法规遵从对比表），“白帽子”的相关法律行为可有一个新的预期。

表 5 “白帽子”漏洞挖掘的法规遵从对比表

法律名称		内容	违法	犯罪
《保守国家秘密法》	现行法律框架	涉密信息系统的漏洞挖掘。	✓	✓
	完善之后	涉密信息系统的漏洞挖掘。	✓	✓
《治安管理处罚法》	现行法律框架	挖掘漏洞造成计算机系统不能正常运行或对其造成危害。	✓	
	完善之后	区分目的，为实现漏洞挖掘而不得已的短暂行为视情况豁免。		
《计算机信息系统安全保护条例》	现行法律框架	漏洞挖掘违反计算机信息系统安全等级保护制度，危害计算机信息系统安全。	✓	
	完善之后	漏洞挖掘违反计算机信息系统安全等级保护制度，危害计算机信息系统安全。	✓	
《刑法》	现行法律框架	挖掘国家事务、国防建设、尖端科学技术领域的计算机信息系统漏洞。		✓
	完善之后	特殊情况下为了执行紧急命令，实现国家安全的目的豁免。		
	现行法律框架	挖掘计算机系统（国家事务、国防建		✓

构建国家层面网络安全命运共同体的 对策建议



政府加强有效监管



企业增强社会责任感



众测平台规范管理流程



“白帽子”提高法律意识

小 结



中国互联网安全大会



360互联网安全中心

- ◆ 一方面，法律应该真正将“白帽子”和众测平台通过适当的**衡量标准**纳入到**安全产业**当中，确实给予他们合法地位。**帽子的颜色并非由“白帽子”自定义**，而是部分取决于企业对“白帽子”和漏洞挖掘行为的态度，及**众测平台的法律定位和安全保障力度**。
- ◆ 另一方面“白帽子”漏洞挖掘行为应**遵从现行法律框架**。在法律规定不完善的情况下，立法可进一步明确“白帽子”漏洞挖掘行为的活动范围及超出该范围构成犯罪的法律要件。

在刑法的**禁止性规定**与《网络安全法（草案二次审议稿）》**规范性规定的双重约束与指引**下，“**疏导**”与“**阻断**”所体现的政策和立法思路能够最终实现“**白帽子**”、众测平台和企业的“**原力**”平衡；安全社区能够持续保持**开放、活跃与正面**，**网络安全行业**更能成为《国家信息化发展战略纲要》所要求的信息产业和**核心技术的典范产业**。

THANK YOU



中国互联网络安全大会



360互联网安全中心